

INTERNAL ISMS AUDIT REPORT

Tumaini Capital Ltd | ISMS-AUD-001 | ISO/IEC 27001:2022 — Clause 9.2 | Fictional case study

Document ID	ISMS-AUD-001 Version 1.0
Audit Title	ISMS Readiness Audit — Pre-Certification Assessment
Audit Scope	ISO/IEC 27001:2022 Clauses 4–10 and all applicable Annex A controls within the certified ISMS boundary (as defined in ISMS-DOC-001)
Audit Dates	9–11 September 2026
Lead Auditor	[To be appointed — must be independent of ISMS implementation] ISO 27001:2022 Clause 9.2 requires auditors to be selected to ensure objectivity and impartiality. The person who built the ISMS cannot audit their own work. Suitable options: a trained staff member from Finance or Operations with no ISMS involvement; an external GRC consultant; or a certification body pre-assessment auditor.
Auditees	CEO; Head of Engineering; Head of Operations; Head of HR/Finance; sample of 6 staff across departments
Methods Used	Document review; staff interviews; system walkthroughs (AWS IAM, Google Workspace admin, CRM audit log, CloudTrail); physical walkthrough of Nairobi HQ and Kisumu office (via video call)
Report Date	15 September 2026

PORTFOLIO NOTE — AUDITOR INDEPENDENCE

ISO/IEC 27001:2022 Clause 9.2 requires that internal auditors are selected to ensure objectivity and impartiality. The person who designed and implemented the ISMS cannot conduct the internal audit of their own work — this would be a conflict of interest and a direct nonconformity.

This report is included in the portfolio as a demonstration of internal audit methodology and knowledge of realistic first-year ISMS findings. In a live engagement, this report would be produced by an independently appointed auditor: a trained staff member from a function with no ISMS involvement (e.g. Finance or Operations), an external GRC consultant, or a certification body pre-assessment auditor.

The methodology, finding classifications, corrective action structure, and conclusions shown here reflect what an independent auditor would produce for an ISMS at this stage of implementation.

1. EXECUTIVE SUMMARY

This report presents the findings of Tumaini Capital's first internal ISMS audit, conducted in accordance with Clause 9.2 of ISO/IEC 27001:2022. The audit was designed as a readiness assessment ahead of the Stage 1 certification audit scheduled for November 2026. The audit assessed all mandatory clauses (4–10) and a sample of Annex A controls prioritized by risk rating from the risk register (ISMS-DOC-006).

The ISMS has made significant progress since its formal initiation in July 2026. The context, scope, risk assessment, risk treatment plan, and Statement of Applicability have been completed. Five policies have been drafted and are awaiting formal approval. The risk treatment plan is approximately 40% complete against its Phase 1 targets.

The audit identified three Major Nonconformities, four Minor Nonconformities, and three Observations. The Major Nonconformities center on formal approval gaps (policies and the SoA have not been signed by top management) and the absence of any staff security awareness training. These must be resolved before the Stage 1 audit. The Minor Nonconformities and Observations are manageable within the current timeline.

The overall audit opinion is: the ISMS is on a credible trajectory toward certification. The foundation artefacts are substantive and well-reasoned. The critical path to Stage 1 readiness runs through the three Major Nonconformity corrective actions.

2. AUDIT SCOPE AND METHODOLOGY

The audit covered the ISMS boundary as defined in ISMS-DOC-001. Documents reviewed included the ISMS Scope Statement, Context Document, Risk Assessment, Risk Treatment Plan, Statement of Applicability, and all five policies. System walkthroughs covered AWS IAM console (MFA status, privileged accounts), Google Workspace admin (MFA enforcement, shared drive access), CRM access controls and audit log configuration, and AWS CloudTrail. Staff interviews included the CEO, Head of Engineering, Head of Operations, Head of HR, and six randomly selected staff members from the Operations and Engineering teams.

Findings are classified as: Major Nonconformity (direct violation of a mandatory ISO 27001:2022 requirement), Minor Nonconformity (partial implementation that could become a Major NC if not corrected), or Observation/OFI (opportunity for improvement that does not directly violate the standard).

3. MAJOR NONCONFORMITIES

The following findings represent direct non-fulfilment of mandatory requirements of ISO/IEC 27001:2022. All three must be closed before the Stage 1 audit.

MNC-001 Major Nonconformity Information Security Policy not formally approved by top management	
ISO/IEC 27001:2022 Reference	Clause 5.2, Clause 7.5.2
Finding	ISMS-POL-001 (Information Security Policy, v1.1) has not been reviewed and signed by the Chief Executive Officer. The document control table shows status 'DRAFT — Pending CEO Approval' and the management sign-off block contains no signature or date. Clause 5.2 requires top management to issue the information security policy; Clause 7.5.2 requires that documented information be appropriately approved. Without formal CEO approval, the policy is not valid as an ISMS document and the management commitment required by Clause 5.1 is not evidenced.
Evidence Reviewed	ISMS-POL-001 reviewed; CEO sign-off block observed to be blank; CEO interview confirmed policy has been reviewed verbally but not yet formally signed.
Required Action	CEO to formally review, sign, and date ISMS-POL-001. ISMS Lead to update document status to 'Approved v1.1' and enter approval date in the Document Register (ISMS-REG-001).
Responsible Owner	CEO / ISMS Lead
Target Completion	4 weeks (by 13 October 2026)

MNC-002 Major Nonconformity Statement of Applicability not formally approved	
ISO/IEC 27001:2022 Reference	Clause 6.1.3(d), Clause 7.5.2
Finding	The Statement of Applicability (ISMS-DOC-008) exists as a workbook tab but carries DRAFT status with no management sign-off recorded. Clause 6.1.3(d) requires the organization to produce a Statement of Applicability that is available as documented information. ISO 27001 certification requires the SoA to be formally approved and version-controlled. An unsigned SoA would be raised as a finding at Stage 1.
Evidence Reviewed	ISMS-DOC-008 (SoA tab in the RTP & SoA workbook) reviewed; document status field shows 'DRAFT — Pending Approval'; no approval signature or date field completed.
Required Action	ISMS Lead and CEO to formally review and approve the SoA. Update the document status to 'Approved v1.0' and record approval date. The SoA must be the version presented to the Stage 1 auditor.
Responsible Owner	ISMS Lead / CEO
Target Completion	4 weeks (by 13 October 2026)

MNC-003 Major Nonconformity No information security awareness training has been conducted	
ISO/IEC 27001:2022 Reference	Clause 7.3, Annex A 6.3
Finding	No security awareness training has been delivered to any of the 85 staff members. ISMS-POL-001 commits to 90% staff training completion within six months of the ISMS going live. The ISMS was formally initiated in July 2026; the commitment window expires January 2027. However, with zero delivery at Month 3, this trajectory is unlikely to be met. Six staff interviewed were unable to identify: the location of the Information Security Policy, how to report a security incident, or the definition of a Restricted information asset.
Evidence Reviewed	Staff interviews (6 of 85 sampled — Operations x3, Engineering x2, HR x1); ISMS Lead confirmed training has been designed but not yet delivered; no training records or attendance sheets found.
Required Action	ISMS Lead to schedule and deliver the first security awareness training session within 6 weeks, covering: the IS Policy, information classification, acceptable use, incident reporting, and phishing awareness. All attendance must be recorded. Target: 90% of staff to receive training before Stage 2 audit.
Responsible Owner	ISMS Lead
Target Completion	6 weeks (by 27 October 2026)

4. MINOR NONCONFORMITIES

The following findings represent partial implementation of requirements. Each must be resolved before the Stage 2 certification audit.

mnc-001 Minor Nonconformity MFA deployment incomplete — not all in-scope accounts protected	
ISO/IEC 27001:2022 Reference	Annex A 8.5, A.5.17, ISMS-POL-002
Finding	The Access Control Policy (ISMS-POL-002) mandates MFA on all AWS, Google Workspace, and CRM access without exception. AWS IAM console review revealed MFA enforced on 3 of 14 Engineering accounts; 4 accounts with console access have no MFA device registered. Google Workspace admin console shows MFA enforcement policy is configured but set to 'optional' rather than 'enforced'. Head of Engineering confirmed rollout is in progress but not complete.
Evidence Reviewed	AWS IAM console reviewed — MFA device count vs. active user count; Google Workspace admin > Security > 2-Step Verification policy settings reviewed; Head of Engineering interview.
Required Action	Head of Engineering to complete MFA deployment across all AWS accounts (enforce via IAM policy, not optional), all Google Workspace accounts, and CRM. Provide a completion report to the ISMS Lead documenting which accounts are enrolled and confirming enforcement is mandatory.
Responsible Owner	Head of Engineering
Target Completion	4 weeks (by 13 October 2026)

mnc-002 Minor Nonconformity Backup recovery test not yet conducted against defined RTO/RPO targets	
ISO/IEC 27001:2022 Reference	Annex A 8.13, A.8.14
Finding	The Backup Policy (committed in the Risk Treatment Plan, target October 2026) defines a Recovery Time Objective of 4 hours and a Recovery Point Objective of 1 hour for the core lending platform. No recovery test has been performed to verify these targets are achievable. Head of Engineering confirmed AWS backup is configured but recovery capability has never been tested. Unverified recovery targets represent an accepted risk that may not match reality.
Evidence Reviewed	Risk Treatment Plan (ISMS-DOC-007) — TRP-008 target date reviewed; Head of Engineering interview; AWS Backup console reviewed (backup jobs exist; restore test logs absent).
Required Action	Head of Engineering to conduct a formal backup recovery test for the core lending platform. Document: test date, scope, steps followed, actual recovery time achieved, comparison against RTO/RPO targets, and any remediation actions identified. Results to be reported at the next management review.
Responsible Owner	Head of Engineering
Target Completion	6 weeks (by 27 October 2026)

mnc-003 Minor Nonconformity Logging policy not formally approved; CloudTrail coverage not confirmed across all regions	
ISO/IEC 27001:2022 Reference	Annex A 8.15, Clause 9.1
Finding	The Risk Treatment Plan commits to a Logging Policy and full AWS CloudTrail coverage (ISMS-DOC-007 TRP-022). No standalone Logging Policy has been drafted or approved. AWS CloudTrail is enabled in eu-west-1 (the primary region) but it was not possible to confirm whether it is enabled in all other regions accessed by the platform. CRM audit logging was stated to be enabled by the Head of Engineering but no screenshot or configuration record was provided during the audit.
Evidence Reviewed	AWS CloudTrail console reviewed (eu-west-1 confirmed; other regions not verified); CRM audit log settings not demonstrated during audit walkthrough; ISMS document register reviewed — no Logging Policy found.
Required Action	Head of Engineering to: (1) Enable and verify CloudTrail across all AWS regions; (2) Confirm CRM audit logging with a screenshot of current configuration; (3) Draft and approve a short Logging Policy (can be a section within an Operations Procedure document) defining what is logged, retention periods, and review frequency.
Responsible Owner	Head of Engineering
Target Completion	4 weeks (by 13 October 2026)

mnc-004 Minor Nonconformity No documented access review conducted since Access Control Policy approval	
ISO/IEC 27001:2022 Reference	Annex A 5.18, A.6.5
Finding	The Access Control Policy (ISMS-POL-002) was approved in June 2026 and requires a quarterly access review across all in-scope systems. Three months have elapsed since approval and no access review has been conducted or documented. The 2025 CRM incident was directly caused by the absence of an access review process; this nonconformity demonstrates that the process defined in the policy has not yet been operationalized.

Evidence Reviewed	ISMS-POL-002 (Periodic Access Reviews) reviewed; Head of Engineering interview — confirmed no access review has been conducted; no access review records found in Google Workspace or ISMS documentation.
Required Action	Head of Engineering to conduct an immediate access review across all in-scope systems (CRM, AWS IAM, Google Workspace) and document the findings. Deactivate any accounts that cannot be justified. Going forward, schedule quarterly access reviews in the ISMS calendar and retain evidence of each review.
Responsible Owner	Head of Engineering
Target Completion	2 weeks (by 29 September 2026) — HIGH PRIORITY

5. OBSERVATIONS AND OPPORTUNITIES FOR IMPROVEMENT

OFI-001 Observation / OFI Incident response tabletop exercise not yet scheduled	
ISO/IEC 27001:2022 Reference	Annex A 5.24, A.5.26
Finding	The Incident Response Policy (ISMS-POL-003) commits to conducting a tabletop exercise within 60 days of policy approval. The policy was approved June 2026; the 60-day window expires August 2026. No tabletop exercise has been scheduled or conducted. While this is not directly raised as a nonconformity (the exercise is a policy commitment rather than a direct standard requirement), the absence of a tested IR process increases risk, particularly given the 2025 CRM incident history.
Evidence Reviewed	ISMS-POL-003 reviewed; ISMS Lead interview — confirmed exercise has not been scheduled; no exercise records found.
Required Action	Schedule and conduct an IR tabletop exercise with ISMS Lead, Head of Engineering, and Head of Operations. Document the scenario, participants, key actions taken, and lessons learned. Use findings to update ISMS-POL-003 if needed.
Responsible Owner	ISMS Lead
Target Completion	Before Stage 1 audit (by November 2026)

OFI-002 Observation / OFI Physical security assessment at Kisumu office not yet initiated	
ISO/IEC 27001:2022 Reference	Annex A 7.1, A.7.2
Finding	The Risk Treatment Plan (ISMS-DOC-007 TRP-028) commits to a physical security assessment at both offices by Month 8 (March 2027). The Nairobi HQ walkthrough was conducted as part of this audit. A video call walkthrough of the Kisumu office was also conducted; however, no formal documented assessment has been initiated or planned. Given that Kisumu staff have access to in-scope systems, a documented physical security assessment is important audit evidence.
Evidence Reviewed	Risk Treatment Plan TRP-028 target reviewed; video call walkthrough of Kisumu office conducted by auditor; Head of Operations confirmed no formal assessment has been scheduled.
Required Action	Head of Operations to schedule and conduct a formal physical security assessment of the Kisumu office, using the same checklist applied to the Nairobi HQ. Document findings and any remediation actions.
Responsible Owner	Head of Operations
Target Completion	Before Stage 1 audit (by November 2026)

OFI-003 Observation / OFI Information security performance metrics not yet being collected	
ISO/IEC 27001:2022 Reference	Clause 9.1
Finding	The ISMS defines five measurable information security objectives (ISMS-POL-001) and a risk register (ISMS-DOC-006). However, no formal monitoring and measurement process has been established to collect and report on performance metrics. As a result, the management review inputs required by Clause 9.3 will be incomplete — the organization cannot currently report against objectives such as leaver deactivation SLA compliance rate, training completion percentage, or patch management SLA adherence.
Evidence Reviewed	ISMS-DOC-006 (IS Objectives) reviewed; ISMS Lead interview — confirmed no metrics dashboard or reporting mechanism exists; no measurement data found.
Required Action	ISMS Lead to define and implement a simple ISMS metrics dashboard (can be a monthly spreadsheet) capturing: leaver deactivation SLA compliance, MFA enrolment rate, training completion rate, open nonconformities, and patch SLA adherence. Begin collecting data before the management review.
Responsible Owner	ISMS Lead
Target Completion	Before management review (by October 2026)

6. CORRECTIVE ACTION SUMMARY

ID	Clause	Type	Priority	Finding Summary	Owner	Target	Status
MNC-001	Cl.5.2, 7.5.2	Major NC	HIGH	IS Policy not formally signed by CEO	CEO / ISMS Lead	13 Oct 2026	Open
MNC-002	Cl.6.1.3(d)	Major NC	HIGH	SoA not formally approved	ISMS Lead / CEO	13 Oct 2026	Open
MNC-003	Cl.7.3, A.6.3	Major NC	HIGH	No awareness training conducted	ISMS Lead	27 Oct 2026	Open
mnc-001	A.8.5, A.5.17	Minor NC	HIGH	MFA deployment incomplete	Head of Engineering	13 Oct 2026	Open
mnc-002	A.8.13, A.8.14	Minor NC	MEDIUM	Backup recovery test not conducted	Head of Engineering	27 Oct 2026	Open
mnc-003	A.8.15, Cl.9.1	Minor NC	MEDIUM	Logging policy not approved; CloudTrail unverified	Head of Engineering	13 Oct 2026	Open
mnc-004	A.5.18, A.6.5	Minor NC	HIGH	Access review not conducted post-policy	Head of Engineering	29 Sep 2026	Open
OFI-001	A.5.24, A.5.26	OFI	MEDIUM	IR tabletop exercise not scheduled	ISMS Lead	Nov 2026	Open
OFI-002	A.7.1, A.7.2	OFI	LOW	Kisumu physical assessment not initiated	Head of Operations	Nov 2026	Open
OFI-003	Cl.9.1	OFI	MEDIUM	IS metrics not being collected	ISMS Lead	Oct 2026	Open

7. AUDIT CONCLUSION

The ISMS is substantively under development and the foundational artefacts — context, scope, risk assessment, risk treatment plan, policies, and Statement of Applicability — are present and demonstrate a well-reasoned approach to the standard's requirements. The quality of documentation produced to date gives confidence that the organization understands its information security risk landscape and has made credible decisions about how to address it.

The three Major Nonconformities are primarily administrative rather than substantive: the policies and SoA exist as documents; they simply have not been formally signed off. This is correctable within weeks. The absence of security awareness training is the most operationally significant gap and requires priority attention given that staff are the primary control for several of the highest-rated risks.

The Stage 1 certification audit is recommended to proceed on the planned November 2026 date, conditional on all three Major Nonconformity corrective actions being closed and evidenced before that date.

Role	Name & Signature	Date
Independent Internal Auditor (appointed separately from ISMS implementation)		
ISMS Lead (Report Recipient — not the auditor)		
CEO (For Information)		